



ARKA HEALTH, INC.

SECURITY INCIDENT RESPONSE & BREACH NOTIFICATION PLAN

Incident procedures under 45 C.F.R. § 164.308(a)(6); breach assessment and notification under 45 C.F.R. §§ 164.400–414

ARKA-SEC-006 · Version 1.0 · Confidential — Internal

Document No.	ARKA-SEC-006
Version	1.0
Effective Date	June 10, 2026
Last Reviewed	June 10, 2026
Document Owner	Arri Kanna, Founder & Chief Executive Officer — Privacy & Security Officer
Approved By	Arri Kanna, Founder & Chief Executive Officer
Classification	Confidential — Internal
Review Cycle	Annual, and upon any material change in operations, systems, or law

This document contains confidential and proprietary information of ARKA Health, Inc. (“ARKA”). It is furnished for informational and compliance purposes, may not be reproduced or disclosed to any third party without the prior written consent of ARKA, and must be returned or destroyed upon request. Nothing in this document constitutes legal advice.

1. PURPOSE AND DEFINITIONS

This Plan establishes the procedures by which ARKA Health, Inc. identifies, responds to, mitigates, documents, and provides notification concerning Security Incidents and Breaches. “**Security Incident**” has the meaning at 45 C.F.R. § 164.304: the attempted or successful unauthorized access, use, disclosure, modification, or destruction of information or interference with system operations in an information system. “**Breach**” has the meaning at 45 C.F.R. § 164.402, subject to the exclusions and the risk-assessment presumption stated therein. “**Discovery**” occurs on the first day a Security Incident or Breach is known to ARKA, or by exercising reasonable diligence would have been known to ARKA, per §§ 164.404(a)(2) and 164.410(a)(2).

2. ROLES

The Security Officer serves as Incident Commander. The Incident Commander may convene an incident team including engineering personnel, outside counsel, the Company’s cyber-liability insurer, and forensic specialists. Only the Chief Executive Officer or outside counsel may make external statements concerning an incident; Workforce Members shall route all inquiries to the Incident Commander.

3. SEVERITY CLASSIFICATION

Severity	Definition	Initial response objective
SEV-1	Confirmed or reasonably suspected unauthorized access to, or acquisition of, ePHI; ransomware on any production system; sustained loss of platform integrity	Containment actions initiated within one (1) hour of discovery; CEO and counsel engaged same day
SEV-2	Compromise of a Workforce credential, endpoint, or non-ePHI production system without confirmed ePHI exposure; material control failure	Containment within four (4) hours; assessment of ePHI exposure within twenty-four (24) hours
SEV-3	Policy violations, attempted intrusions, and anomalies without evidence of compromise (incl. Unsuccessful Security Incidents)	Triage within two (2) business days; logged and trended

4. RESPONSE PHASES

- Identification and reporting.** Every Workforce Member shall report a suspected incident immediately, and in no event later than twenty-four (24) hours after becoming aware, to security@getarka.health. External parties may report vulnerabilities to the same address, which is published on the Company’s website; good-faith security research conducted within the published scope shall not be the subject of legal action by the Company.
- Containment.** The Incident Commander shall isolate affected systems, revoke implicated credentials and tokens, preserve volatile evidence before destructive remediation, and snapshot affected storage.
- Eradication and recovery.** Root cause shall be identified and removed; systems are restored from trusted artifacts and backups (ARKA-SEC-007); restored systems are monitored at heightened sensitivity for no fewer than fourteen (14) days.

4. **Forensic preservation.** A chain-of-custody record shall be maintained for all evidence; clocks, log extracts, and system images are preserved in the incident file for six (6) years.
5. **Post-incident review.** For SEV-1 and SEV-2 incidents, a written post-incident report — timeline, root cause, data-exposure analysis, corrective actions with owners and dates — shall be completed within ten (10) business days of closure and presented to the Security & Compliance Committee.

5. BREACH RISK ASSESSMENT

An impermissible acquisition, access, use, or disclosure of unsecured PHI is **presumed** a Breach unless ARKA (in coordination with the affected Customer, as the BAA provides) demonstrates a low probability of compromise through a documented risk assessment addressing, at minimum, the four factors of 45 C.F.R. § 164.402(2): (i) the nature and extent of the PHI involved, including identifiers and likelihood of re-identification; (ii) the unauthorized person who used the PHI or to whom disclosure was made; (iii) whether the PHI was actually acquired or viewed; and (iv) the extent to which the risk has been mitigated. Each assessment, including its conclusion and approver, shall be retained for six (6) years. Encryption consistent with ARKA-SEC-004 renders PHI “secured”; the loss of properly encrypted data without the key is not a Breach of unsecured PHI.

6. NOTIFICATION OBLIGATIONS

1. **As business associate.** ARKA shall notify each affected Customer of a Breach of unsecured PHI without unreasonable delay and in no event later than the period specified in the applicable BAA (ten (10) business days under ARKA-LGL-001) and shall provide the content described at 45 C.F.R. § 164.410(c), supplementing as information becomes available. Unless the BAA provides otherwise, notification to individuals, the Secretary, and the media under §§ 164.404–164.406 is the Customer’s obligation; ARKA shall provide all reasonable cooperation.
2. **Where delegated.** If a BAA delegates individual notification to ARKA, ARKA shall provide written notice by first-class mail (or email where the individual has agreed) without unreasonable delay and within sixty (60) days of discovery, containing the elements of § 164.404(c); substitute notice, media notice for five hundred (500) or more residents of a state, and notice to the Secretary shall follow §§ 164.404(d), 164.406, and 164.408 respectively.
3. **Law enforcement delay.** Notification may be delayed upon the documented request of a law-enforcement official in accordance with 45 C.F.R. § 164.412.
4. **State law.** Counsel shall be consulted regarding state breach-notification statutes, which may impose shorter deadlines, regulator notices, or content requirements beyond HIPAA; the more stringent requirement governs.
5. **Insurance and contracts.** The Incident Commander shall provide timely notice under the Company’s cyber-liability policy and any contractual notice provisions beyond the BAA.

7. TESTING

This Plan shall be exercised at least annually by tabletop simulation, including at least one scenario involving ransomware and one involving compromise of a managed subprocessor, with results and improvement items documented and tracked to closure.

DOCUMENT CONTROL & REVISION HISTORY

Version	Date	Author / Reviewer	Description of Change
0.9	May 22, 2026	A. Kanna (drafting); external review pending	Initial draft circulated for internal review and counsel comment.
1.0	June 10, 2026	A. Kanna, Privacy & Security Officer	Adopted as effective policy of ARKA Health, Inc. by written approval of the undersigned officer.

ADOPTION AND APPROVAL

The undersigned, being the duly designated Privacy Officer and Security Officer of ARKA Health, Inc., hereby adopts this document as an official policy of the Company, effective as of the Effective Date set forth on the cover page hereof. This document shall be reviewed no less frequently than annually and upon any material change to the Company's operations, information systems, or applicable law, and may be amended only in accordance with ARKA-GOV-001 (Information Security & Compliance Program Charter).

ARKA HEALTH, INC.

By: _____

Name: Arri Kanna

Title: Founder & Chief Executive Officer; Privacy & Security Officer

Date: June 10, 2026